

CX Help Document (Mining System)

Version: 1.0 Date: 2026-03-20

How to use this document (for CX)

This document explains:

- What the public site does
- What the admin dashboard does (internal workflows CX may need to support)
- What security controls are in place
- Which issues CX can approach the engineering team for
- The yearly hosting/SSL/DB maintenance fee (fill in your amount)

Yearly Hosting / SSL / Database Maintenance Fee

Production support plan:

- Yearly fee: varies by provider (hosting + SSL renewal + database maintenance)
- Billing cadence: annually
- What is typically covered (adjust to your contract wording):
 - Hosting uptime monitoring and routine maintenance
 - SSL certificate renewal/management
- Database maintenance (backups, retention, health checks)
- Security updates/patches for server dependencies
- Incident response for security or availability issues

Support Contact (CX)

- Phone: TBD (share the number you want customers to call)

Security measures already in place

HTTP & application hardening

- Uses `helmet()` to set common secure HTTP headers
- Disables `x-powered-by`
- Uses `express.json({ limit: '1mb' })` to limit request body size
- Sets `app.set('trust proxy', 1)` to ensure correct handling of secure cookies behind a load balancer

CORS policy

- `cors` is configured to allow:
 - `same-origin` / non-browser requests
 - the configured `CORS_ORIGIN` (defaults to `http://localhost:5173`)
- `credentials: true` is enabled for authenticated cookie usage

Admin authentication (protected `/api/admin/*`)

- Admin sessions are stored in an `httpOnly` cookie (`COOKIE_NAME`, default `admin_session`)
- Cookie flags:
 - `httpOnly: true`
 - `secure: true` in production only
 - `sameSite: 'lax'`
- Admin access uses JWT verification and `requireAuth` middleware
- Session invalidation:
 - if the admin user was updated after the token was issued, the API rejects the session (forces re-login after sensitive changes)

Role-based access control (RBAC)

- Requests to admin routes must pass both:
 - authentication (`requireAuth`)
 - authorization (`requirePermission('<permission.key>')`)
- Permissions are loaded from the DB per request

Rate limiting (brute-force and abuse protection)

- `/api` has a general rate limit
- Extra limits protect sensitive flows:
 - admin login (brute-force)
 - OTP verification and password reset (OTP brute-force)
 - uploads (upload abuse)

OTP security (admin email verification and password reset)

- OTP codes are generated securely and compared using a SHA-256 hash (OTP hashes are stored; OTP secrets are not stored in plaintext).
- Expiration windows:
 - email verification OTP: 15 minutes
 - password reset OTP: 30 minutes
- Outstanding OTPs are cleared when an admin user is disabled.

Upload security (images and resumes)

• Gallery image uploads: ◦ allowed MIME types: image/jpeg, image/png, image/webp ◦ max file size: 8MB ◦ uses a server-generated UUID filename ◦ constrains gallery directories using a safe sectionSlug regex	• Team photo uploads: ◦ allowed MIME types: image/jpeg, image/png, image/webp ◦ max file size: 6MB ◦ server-generated UUID filename • Public media access protection: ◦ unpublished team photos are hidden via an Express route guard (not just static serving)	• Careers resume uploads: ◦ only PDF resumes are accepted (application/pdf or .pdf) ◦ max file size: 5MB ◦ resumes are stored with UUID filenames
---	--	--

Auditing and logging

• Sensitive actions write to audit_logs: ◦ auth events (login success/failure, OTP/reset flows) ◦ content changes (gallery images, sections, team members, settings) ◦ user management actions	• Audit logs never break the API: ◦ audit logging failures are swallowed (fail-safe)	• Server errors: ◦ production responses avoid leaking internals ◦ development may include more detail
---	---	---

Public site functionality (end-user experience)

Health check

- GET /api/healthz returns { ok: true }

Site settings

• GET /api/settings	• Used by the React site to render configurable content blocks (e.g., About, Nav, Solutions, Services, Projects).
---	---

Team

• GET /api/team	• Shows only is_published = true team members on the public site.	• Team photos: ◦ unpublished photos remain inaccessible to public users.
---	---	---

Gallery

• GET /api/gallery ◦ returns published gallery sections and their published images	• GET /api/gallery/home-slides ◦ returns up to 12 homepage hero slides from gallery_images where: ▪ is_published = true ▪ is_home_slide = true
---	---

Contact form

• POST /api/contact	• Payload is validated server-side.	• Submissions are stored in contact_us_submissions.
---	---	---

Careers

1. View job openings ◦ GET /api/careers/openings ◦ only shows published openings	2. Upload resume (client side) ◦ POST /api/careers/resume-upload ◦ accepts only PDF up to 5MB ◦ returns resumeUrl	3. Apply to a job ◦ POST /api/careers/apply ◦ payload is validated server-side ◦ application is stored in career_applications
---	---	---

Admin dashboard functionality (internal workflows)

Authentication and account recovery

• Login: ◦ POST /api/admin/login ◦ rate-limited to reduce brute-force ◦ writes audit logs for success/failure • Logout: ◦ POST /api/admin/logout • Get current admin profile: ◦ GET /api/admin/me	Email verification (OTP) • Request OTP: ◦ POST /api/admin/users/verification/request • Confirm OTP (+ optional new password): ◦ POST /api/admin/users/verification/confirm	Password reset (OTP) • Request reset OTP: ◦ POST /api/admin/users/password-reset/request • Confirm reset: ◦ POST /api/admin/users/password-reset/confirm
--	--	--

Admin user management

- | | | |
|---|---|---|
| <ul style="list-style-type: none"> List users: <ul style="list-style-type: none"> GET /api/admin/users | <ul style="list-style-type: none"> Create user: <ul style="list-style-type: none"> POST /api/admin/users supports onboarding with OTP-first (placeholder password hash stored until verification) | <ul style="list-style-type: none"> Update user: <ul style="list-style-type: none"> PUT /api/admin/users/:id Disable user: <ul style="list-style-type: none"> DELETE /api/admin/users/:id (soft-disable; also clears outstanding OTP tokens) |
|---|---|---|

Admin settings

- Only super_admin can read/update site settings:
 - GET /api/admin/settings
 - PUT /api/admin/settings

Team management

- | | | |
|---|--|---|
| <ul style="list-style-type: none"> List team: <ul style="list-style-type: none"> GET /api/admin/team | <ul style="list-style-type: none"> Create/update/delete team members: <ul style="list-style-type: none"> POST /api/admin/team PUT /api/admin/team/:id DELETE /api/admin/team/:id (soft delete via is_published = false) DELETE /api/admin/team/:id/hard (super admin only) | <ul style="list-style-type: none"> Upload team photo: <ul style="list-style-type: none"> POST /api/admin/team/photo-upload |
|---|--|---|

Gallery management

- | | | |
|--|--|---|
| <ul style="list-style-type: none"> Manage gallery sections: <ul style="list-style-type: none"> GET /api/admin/gallery/sections POST /api/admin/gallery/sections PUT /api/admin/gallery/sections/:id DELETE /api/admin/gallery/sections/:id (soft delete: unpublishes section + its images) | <ul style="list-style-type: none"> Manage gallery images metadata: <ul style="list-style-type: none"> GET /api/admin/gallery/images?sectionSlug=... PUT /api/admin/gallery/images/:id DELETE /api/admin/gallery/images/:id (soft delete: unpublishes image) | <ul style="list-style-type: none"> Upload gallery images: <ul style="list-style-type: none"> POST /api/admin/gallery/images/upload requires sectionSlug, accepts image files only |
|--|--|---|

Contact and careers submissions (admin)

- | | |
|--|--|
| <ul style="list-style-type: none"> Contact submissions: <ul style="list-style-type: none"> GET /api/admin/contact-submissions?limit=... Career applications: <ul style="list-style-type: none"> GET /api/admin/career-applications?limit=...&openingId=... | <ul style="list-style-type: none"> Career openings management: <ul style="list-style-type: none"> GET /api/admin/career-openings POST /api/admin/career-openings PUT /api/admin/career-openings/:id DELETE /api/admin/career-openings/:id (soft delete via is_published = false) |
|--|--|

Audit logs

- | | | |
|---|--|---|
| <ul style="list-style-type: none"> GET /api/admin/audit-logs | <ul style="list-style-type: none"> Supports filtering via query params (action/resource/actor/etc.) | <ul style="list-style-type: none"> IP exposure is restricted: <ul style="list-style-type: none"> only super_admin can request IP inclusion |
|---|--|---|

What CX can approach engineering for (support scope)

CX can contact the engineering team when issues relate to any of the following:

Public site content and visibility

- | | | |
|---|---|--|
| <ul style="list-style-type: none"> Missing/unpublished team members or photos on the public site | <ul style="list-style-type: none"> Gallery images not appearing after being marked published | <ul style="list-style-type: none"> Homepage slider not updating as expected |
|---|---|--|

Form submissions

- | | | |
|---|--|---|
| <ul style="list-style-type: none"> Contact form submissions not being stored | <ul style="list-style-type: none"> Career applications not being stored | <ul style="list-style-type: none"> Resume upload failures (PDF-only and size limits) |
|---|--|---|

Admin access and account recovery

- | | | |
|---|--|---|
| <ul style="list-style-type: none"> Admin login failures (wrong credentials, disabled user, OTP not received) | <ul style="list-style-type: none"> OTP confirmation issues for: <ul style="list-style-type: none"> email verification password reset | <ul style="list-style-type: none"> Admin password reset issues |
|---|--|---|

Admin upload and publishing workflows

- | | | |
|---|--|--|
| <ul style="list-style-type: none">• Gallery image upload failures (file type/size/sectionSlug issues) | <ul style="list-style-type: none">• Team photo upload failures (file type/size issues) | <ul style="list-style-type: none">• Unexpected behavior when publishing/unpublishing content |
|---|--|--|

Security and incident reporting

- | | | |
|---|---|--|
| <ul style="list-style-type: none">• Suspicious activity or suspected account compromise | <ul style="list-style-type: none">• Report of suspected vulnerabilities | <ul style="list-style-type: none">• Requests to rotate/review secrets (JWT secret, SMTP credentials, etc.) |
|---|---|--|

Troubleshooting quick reference

401 Unauthorized

- | | |
|--|---|
| <ul style="list-style-type: none">• Admin cookie missing/expired or invalid. | <ul style="list-style-type: none">• Fix: re-login, and verify account status is active. |
|--|---|

403 Forbidden

- | | |
|---|--|
| <ul style="list-style-type: none">• Admin user authenticated but missing required permission key. | <ul style="list-style-type: none">• Fix: update RBAC permissions via user/role administration. |
|---|--|

400 Bad Request

- | | |
|---|--|
| <ul style="list-style-type: none">• Input validation failed (zod schema). | <ul style="list-style-type: none">• Common causes:<ul style="list-style-type: none">◦ invalid <code>sectionSlug</code>◦ unsupported file type◦ payload missing required fields |
|---|--|

429 Too Many Requests

- | | |
|--|--|
| <ul style="list-style-type: none">• Rate limit triggered (OTP brute-force protection, login brute-force, upload abuse protection). | <ul style="list-style-type: none">• Fix: wait for the window to reset and retry. |
|--|--|

Upload errors

- | | | |
|--|---|---|
| <ul style="list-style-type: none">• Gallery/team images: only jpg/png/webp are accepted. | <ul style="list-style-type: none">• Gallery/team images: respect max file size (8MB gallery, 6MB team). | <ul style="list-style-type: none">• Resumes: only PDF accepted and must be <= 5MB. |
|--|---|---|

Converting this document to PDF

- | | | |
|---------------------------|---|---|
| <p>If you want a PDF:</p> | <ul style="list-style-type: none">• Use any Markdown-to-PDF tool of your choice (VSCode extension, web tool, etc.). | <ul style="list-style-type: none">• Or if you have pandoc installed:
<code>pandoc docs/CX-Help-Doc.md -o docs/CX</code> |
|---------------------------|---|---|